Software Engineering
Lab – 5

Name: Shreya Ajith

SRN: PES2UG24CS480

SEC: H

Before

Bandit Report

```
[main]  INFO    profile include tests: None
[main]  INFO    profile exclude tests: None
[main]  INFO    cli include tests: None
[main]  INFO    cli exclude tests: None
[main]  INFO    running on Python 3.13.14
Run started:2026-10-14 06:32:30.448258+00:00

Test results:
>> Issue: [B110:try_except_pass] Try, Except, Pass detected.
   Severity: Low   Confidence: High
   CWE: CWE-703 (https://cwe.mitre.org/data/definitions/703.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b110_try_except_pass.html
   Location: .\library_catalog_system.py:26:4
25              catalog[book_id]["copies"] += 1
26          except:
27              pass
28

--------------------------------------------------
>> Issue: [B307:blacklist] Use of possibly insecure function - consider using safer ast.literal_eval.
   Severity: Medium   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b307-eval
   Location: .\library_catalog_system.py:42:11
41          days = days_overdue
42          fine = eval(calc_expr)
43          return fine

--------------------------------------------------
>> Issue: [B324:hashlib] Use of weak MD5 hash for security. Consider usedforsecurity=False
   Severity: High   Confidence: High
   CWE: CWE-327 (https://cwe.mitre.org/data/definitions/327.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b324_hashlib.html
   Location: .\library_catalog_system.py:47:11
46      def generate_patron_hash(patron_id):
47          return hashlib.md5(patron_id.encode()).hexdigest()
48
```

```
>> Issue: [B311:blacklist] Standard pseudo-random generators are not suitable for security/cryptographic purposes.
   Severity: Low   Confidence: High
   CWE: CWE-330 (https://cwe.mitre.org/data/definitions/330.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b311-random
   Location: .\library_catalog_system.py:51:11
50      def generate_temp_patron_pin():
51          return random.randint(1000, 9999)
52

--------------------------------------------------
>> Issue: [B605:start_process_with_a_shell] Starting a process with a shell, possible injection detected, security issue.
   Severity: High   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b605_start_process_with_a_shell.html
   Location: .\library_catalog_system.py:58:4
57          f.close()
58          os.system("echo Catalog backup exported to: " + filename)
59

--------------------------------------------------

Code scanned:
        Total lines of code: 53
        Total lines skipped (#nosec): 0
        Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0

Run metrics:
        Total issues (by severity):
                Undefined: 0
                Low: 2
                Medium: 1
                High: 2
        Total issues (by confidence):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 5
Files skipped (0):
```

Found 5 security issues, including unsafe eval(), weak MD5 hashing, insecure random PIN generation, bare except, and shell command execution.

Pylint Report

```
************* Module library_catalog_system
library_catalog_system.py:73:0: C0304: Final newline missing (missing-final-newline)
library_catalog_system.py:15:0: C0116: Missing function or method docstring (missing-function-docstring)
library_catalog_system.py:15:0: C0103: Function name "issueBook" doesn't conform to snake_case naming style (invalid-name)
library_catalog_system.py:15:0: W0102: Dangerous default value [] as argument (dangerous-default-value)
library_catalog_system.py:19:25: C0209: Formatting a regular string which could be an f-string (consider-using-f-string)
library_catalog_system.py:23:0: C0116: Missing function or method docstring (missing-function-docstring)
library_catalog_system.py:26:4: W0702: No exception type(s) specified (bare-except)
library_catalog_system.py:30:0: C0116: Missing function or method docstring (missing-function-docstring)
library_catalog_system.py:32:7: C0121: Comparison 'catalog.get(book_id) == None' should be 'catalog.get(book_id) is None' (singleton-comparison)
library_catalog_system.py:34:4: R1703: The if statement can be replaced with 'return bool(test)' (simplifiable-if-statement)
library_catalog_system.py:34:4: R1705: Unnecessary "else" after "return", remove the "else" and de-indent the code inside it (no-else-return)
library_catalog_system.py:31:4: W0612: Unused variable 'late_fee' (unused-variable)
library_catalog_system.py:40:0: C0116: Missing function or method docstring (missing-function-docstring)
library_catalog_system.py:42:11: W0123: Use of eval (eval-used)
library_catalog_system.py:41:4: W0612: Unused variable 'days' (unused-variable)
library_catalog_system.py:46:0: C0116: Missing function or method docstring (missing-function-docstring)
library_catalog_system.py:50:0: C0116: Missing function or method docstring (missing-function-docstring)
library_catalog_system.py:54:0: C0116: Missing function or method docstring (missing-function-docstring)
library_catalog_system.py:55:8: W1514: Using open without explicitly specifying an encoding (unspecified-encoding)
library_catalog_system.py:55:8: R1732: Consider using 'with' for resource-allocating operations (consider-using-with)
library_catalog_system.py:61:0: C0116: Missing function or method docstring (missing-function-docstring)
library_catalog_system.py:6:0: W0611: Unused import csv (unused-import)

-----------------------------------
Your code has been rated at 5.32/10
```

The code scored 5.32/10 and had issues like missing docstrings, incorrect naming, unused variables, unsafe eval(), and poor file handling.

Flake8 Report

```
library_catalog_system.py:6:1: F401 'csv' imported but unused
library_catalog_system.py:26:5: E722 do not use bare 'except'
library_catalog_system.py:31:5: F841 local variable 'late_fee' is assigned to but never used
library_catalog_system.py:32:29: E711 comparison to None should be 'if cond is None:'
library_catalog_system.py:41:5: F841 local variable 'days' is assigned to but never used
library_catalog_system.py:73:7: W292 no newline at end of file
```

Found 6 issues, including an unused import, bare except, unused variables, incorrect comparison with None, and a missing final newline.

After

Bandit Report

```
[main]  INFO    profile include tests: None
[main]  INFO    profile exclude tests: None
[main]  INFO    cli include tests: None
[main]  INFO    cli exclude tests: None
[main]  INFO    running on Python 3.13.14
Run started:2026-10-14 06:34:51.770254+00:00

Test results:
        No issues identified.

Code scanned:
        Total lines of code: 55
        Total lines skipped (#nosec): 0
        Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0

Run metrics:
        Total issues (by severity):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 0
        Total issues (by confidence):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 0
Files skipped (0):
```

No security issues were identified after fixing the reported vulnerabilities.

Pylint Report

```
--------------------------------------------------------------------
Your code has been rated at 10.00/10 (previous run: 5.32/10, +4.68)
```

The code scored 10/10 after fixing the code quality issues and improving readability.

Flake8 Report

The report is empty because all the formatting and style issues were fixed.

Known Issue Table — Static Code Analysis

Issue	Type	Line(s)	Description	Fix Approach
Mutable default argument	Bug	15	active_issues=[] is shared between calls when the default list is used.	Changed default to None and initialized a new list inside issue_book().
Bare except	Bug / Reliability	26	Catches every exception and silently ignores errors, hiding unexpected failures.	Removed the broad try/except; return_book() now checks whether the book ID exists.
Unsafe eval()	Security	42	eval(calc_expr) can execute arbitrary Python expressions supplied as input.	Removed eval(); calculate_fine() now accepts a numeric daily_rate and calculates days_overdue * daily_rate.
Weak MD5 hash	Security	47	MD5 is not suitable for security-sensitive hashing.	Replaced hashlib.md5 with hashlib.sha256 and encoded the patron ID as UTF-8.
Insecure random PIN	Security	51	random.randint() is not designed for security-sensitive values such as PINs.	Replaced random with secrets.randbelow() to generate a four-digit PIN securely.
Shell command execution	Security	58	os.system() launches a shell to print a status message and can introduce command-injection risk.	Removed os.system(); used print() to display the export confirmation.
File handling	Code quality	55–56	open() did not specify an encoding and the file was closed manually.	Used with open(..., encoding='utf-8') so the file closes automatically.
Unused import	Code quality	6	The csv module was imported but never used.	Removed the unused csv import.
Unused variables	Code quality	31, 41	late_fee and days were assigned but not used.	Removed the unused variables; the fine is calculated directly from the provided arguments.
None comparison	Code quality	32	Compared catalog.get(book_id) to None using ==.	Replaced the comparison with an explicit membership check, avoiding the unnecessary None comparison.
Missing docstrings	Code quality	15, 23, 30, 40, 46, 50, 54, 61	Functions lacked descriptions of their purpose.	Added docstrings to the functions.
Function naming	Style	15	issueBook does not follow Python snake_case naming conventions.	Renamed it to issue_book().
String formatting	Style	19	Used percent-based formatting to build a message.	Replaced it with an f-string.
Missing final newline	Style	73	The original source file did not end with a newline.	Saved the updated file with a final newline.